Phishing Email Detection & Awareness Report

What eight emails taught me about spotting phishing, plus a simple guide for employees

Analysis type	**Email header, sender and link analysis (nothing clicked)**
Date	**October 2026**
Submitted by	**Preetam Karoshi, Cyber Security Intern**

8 emails analyzed • 6 Phishing • 1 Suspicious • 1 Safe

The phishing samples come from a public research collection of real emails; one genuine email from the author's own inbox is included as a safe comparison, with personal details removed. No link was clicked and no attachment was opened. Web addresses are written in “defanged” form (hxxp, [.]) so nobody can click one by accident.

01 — SUMMARY

What I did and what I learned

Phishing is when someone sends a fake message that looks like it comes from a company or person you trust, hoping you will click a link, open a file, reply, or hand over a password or money. For this task I worked like a junior security analyst: I collected eight emails, took each one apart, and decided whether it was **Safe**, **Suspicious** or **Phishing**.

The eight emails were the example from my task brief, six real emails from a public collection of phishing samples, and one genuine email from my own inbox to compare against. **Six came out as Phishing, one as Suspicious and one as Safe.**

MY FOUR BIGGEST LESSONS

1. **The name in the "From" line is easy to fake.** The real address behind it tells the truth. "Microsoft account team" was actually sent from access-accsecurity[.]com.
2. **Technical checks help, but they don't settle it.** Three fakes failed the checks (SPF, DKIM, DMARC), yet a scam sent from a real Gmail account and a stranger's lure delivered through a real Google service both passed everything.
3. **Pressure is the common ingredient.** A deadline, fear of losing your account, or a prize. When an email rushes you, slow down.
4. **Not every phishing email has a link.** Three of mine (S2, S3 and S6) only wanted a reply, and in two of them the "buttons" just opened an email to the attacker.

HOW TO READ THIS REPORT

The first part shows how I analyzed the emails and what I found, one case at a time. The second part is a plain-language awareness guide for employees: how an attack works, the red flags, do's and don'ts, and what to do after a mistake. The report ends with supporting evidence and a short conclusion. Every email gets one of three verdicts:

SAFE SUSPICIOUS PHISHING

02 — METHOD

How I analyzed each email

1. **Collect.** The example from my task brief, six real samples from a public phishing collection, and one genuine email from my inbox as the “safe” control.
2. **Read the headers.** Who really sent it, the route it took, and what the SPF, DKIM and DMARC checks said, using the Google Admin Toolbox Messageheader tool and MXToolbox.
3. **Check the sender.** Compare the display name with the real address, look for lookalike domains, and compare the From, Reply-To and Return-Path addresses.
4. **Check the links.** Read the real destination from the email's source without clicking, and write it in defanged form.
5. **Spot the indicators.** Urgency, generic greetings, odd wording, attachments, and requests for passwords, codes or money.
6. **Classify.** Safe, Suspicious or Phishing, using the scale below.
7. **Write guidance.** Prevention tips and do's and don'ts that a non-technical employee can follow.

VERDICT SCALE

SAFE

Expected sender, the domain matches the brand, all checks pass, and there is no pressure or unusual request.

SUSPICIOUS

Something doesn't add up, or I can't verify it. Don't click; check through another channel first.

PHISHING

Clear signs of deception: a forged or lookalike sender, mismatched reply address or failed checks, plus pressure and a request to click, reply or pay.

THE THREE CHECKS, IN PLAIN WORDS

SPF
A list of mail servers the domain owner allows to send email for them.

DKIM
A digital signature showing the message really came from that domain and wasn't changed on the way.

DMARC
The domain owner's rule for what to do when SPF or DKIM fail: nothing, quarantine, or reject.

TOOLS AND SAFETY RULES

Tools: Google Admin Toolbox Messageheader, MXToolbox Email Header Analyzer, the email source in a plain-text viewer, and a small read-only helper script (included in the repository) that lists the key fields of each email.

Safety: no link was clicked and no attachment was opened. Raw emails are not stored, web addresses are defanged, and personal details were removed.

03 — RESULTS

Results at a glance

ID	EMAIL	MAIN RED FLAGS	SPF / DKIM / DMARC	VERDICT
S1	“Your account will be locked” (task example)	Urgency, generic greeting, link to an unrelated domain	no headers	PHISHING
S2	Fake Microsoft sign-in alert (lookalike domain)	Three different sender domains, Gmail reply address, “buttons” that email the attacker	**none** / **none** / **error**	PHISHING
S3	Same alert, forging microsoft[.]com	Forged sender, Reply-To to another domain	**none** / **fail** / **fail**	PHISHING
S4	Fake bank “verify your email”	Bank-looking subdomain of an unrelated domain, link hidden behind a Bing redirect, “Dear Client”, pressure	**none** / **fail** / **fail**	PHISHING
S5	Fake crypto “withdrawal error” with PDF	Free Gmail sender, Google Drive link hidden in the PDF, emoji-filled subject	**pass** / **pass** / **pass***	PHISHING
S6	“European Central Bank” fund release	Fake ecb[.]com domain, Gmail reply address, “dormant fund” story	**softfail** / **none** / **fail**	PHISHING
S7	Google “collection” invite from a stranger	Genuine Google email carrying a stranger's link; gibberish title	**pass** / **pass** / **pass**	SUSPICIOUS
S8	LinkedIn legal notice (my inbox)	None. Every link is on linkedin[.]com and there is no pressure	**pass** / **pass** / **pass**	SAFE

HOW TO READ THE CHECK COLUMNS

pass = the check succeeded. **fail** = it ran and failed, a strong warning sign. **softfail** = failed but treated gently. **none** = the domain published no rule or signature, or the message wasn't signed. **error** = the rule couldn't be read properly.

*S5 passes only because the scammer used a real Gmail account. The checks prove the message came from Gmail, not that the sender can be trusted. S7 passes because Google really did send it. This is why the checks help but are never the whole story.

The textbook example and a fake Microsoft alert

S1 · Task brief example

PHISHING

“Your account will be locked”

Subject: “Urgent: Your Account Will Be Locked” · Signed: “Security Team” · Only the body was available, so no header checks were possible.

- **Urgency and fear:** “immediately”, “within 24 hours”, “permanent account lock”.
- **Generic greeting:** “Dear User” instead of my name.
- **Vague sender:** “Security Team” with no company name and no account details.
- **Suspicious link:** secure-account-verify[.]com is a made-up name stuffed with “secure” and “verify”, not a real company's domain.

How the attack works: the attacker frightens you into acting fast, then sends you to a fake page that looks like a login or verification form. Whatever you type goes straight to them.

Verdict: Phishing. Pressure, generic wording and a link to an unrelated domain.

S2 · Public sample 10 · 8 Sep 2023

PHISHING

Fake Microsoft sign-in alert (lookalike domain)

Sent as “Microsoft account team” <no-reply@access-accsecurity[.]com> · Subject: “Microsoft account unusual signin activity”

SPF none | DKIM none (not signed) | DMARC error

- The real sender domain is access-accsecurity[.]com, not microsoft.com. It only borrows Microsoft's name.
- **Three different addresses in one email:** From (access-accsecurity[.]com), Return-Path (thcultarfdes[.]co[.]uk) and a Gmail Reply-To.
- **Invented fear:** “a user from Russia/Moscow just logged into your account”, with made-up sign-in details.
- **No normal link:** “Report The User” and “click here” are mailto: links that open an email to the attacker's Gmail address.

How the attack works: this is reply-based phishing. The attacker wants a conversation. Once you write back, the next step is usually a request for your password or a security code “to secure the account”.

Verdict: Phishing. Lookalike sender, mismatched addresses, no signature, and a fake emergency.

A forged sender and a fake bank notice

S3 · Public sample 101 · 3 Nov 2022

PHISHING

The same alert, now forging microsoft[.]com

Sent as “Microsoft account team” <no-reply@microsoft[.]com> · Same subject and wording as S2

SPF none | DKIM fail | DMARC fail

- The From address is forged to look exactly like Microsoft's. Anyone can type any address into that line.
- **The forgery was caught:** DKIM failed (“no key for signature”) and DMARC failed with the action “reject”, so Microsoft's own domain rule says this email should be thrown away.
- Reply-To points to a different domain (usual-assist[.]com) and the message really came through nisihfjoz[.]co[.]uk.
- Same invented Russia/Moscow sign-in story and the same mailto “buttons”.

How the attack works: this is spoofing. Email doesn't check the From line by itself. SPF, DKIM and DMARC are the checks that expose a forgery, which is why companies should publish them and mail systems should enforce them.

Verdict: Phishing. Putting S2 and S3 side by side shows one message sent with two sender tricks: a lookalike domain and a forged one.

S4 · Public sample 2 · 20 Sep 2023

PHISHING

Fake bank “verify your email” notice

Sent as “MashreqAlerts” <postmaster@digitalmashreq[.]mg[.]tdi[.]tc> · Subject ends with “(MOVE TO INBOX)”

SPF none | DKIM fail | DMARC fail

- **Bank name in the wrong place:** “digitalmashreq” is only a subdomain label in front of an unrelated domain (tdi[.]tc). What matters is the end of the domain.
- It was sent through a bulk-mail service (Mailgun), not the bank's own servers, and the signature and domain-rule checks failed.
- “(MOVE TO INBOX)” asks me to rescue it from the spam folder, so the sender knew filters were catching it.
- “Dear Client” plus pressure: “our previous email was ignored. Please address the instructions promptly.”
- The “Sign in to verify your email” button goes through a Bing redirect link (bing[.]com/ck/a?…), hiding the real destination behind a trusted name. Real social-media links in the footer make it look authentic.

How the attack works: a link like this normally leads to a fake bank login page that records your username and password. I did not open it, so that last step is the usual pattern rather than something I saw.

Verdict: Phishing.

A crypto lure with a PDF and a “central bank” scam

S5 · Public sample 53 · 17 Sep 2022

PHISHING

Fake crypto “withdrawal error” with a PDF attachment

Sent as “Cato” from a personal Gmail address, to “undisclosed recipients” · Subject: “❌ /// Withdrawal error. /AMOUNT: **** USD/ You need to add a withdrawal address…”

SPF pass | DKIM pass | DMARC pass

- **It passes every check only because it came from a real Gmail account.** A pass proves the origin, not the intent.
- A personal Gmail address sending a “withdrawal” notice, to a hidden list of recipients: a mass mailing.
- The subject is stuffed with an emoji, slashes and a fake amount (“AMOUNT: **** USD”) to look like an automated alert and slip past filters.
- The body is only a Google Drive link, and the attached PDF (sSZt7uix.pdf, about 17 KB) holds another Google Drive link. I found that by reading the file's text only; I never opened it. A trusted site like Google Drive hides the scam behind a familiar name.

How the attack works: a made-up money problem makes you worry. The link then usually asks you to “fix” your wallet or account, which is how logins or recovery phrases get stolen. I did not follow the link to confirm.

Verdict: Phishing.

S6 · Public sample 115 · 15 Nov 2022

PHISHING

“European Central Bank” fund-release scam

Sent as “Jean Patrick” <j.patrick@ecb[.]com> · Subject: “Final Fund Release Notice!!!”

SPF softfail | DKIM none | DMARC fail

- **Fake authority:** it claims to be the European Central Bank, but uses ecb[.]com. The bank's real website is ecb[.]europa[.]eu.
- Reply-To is a Gmail address and the body gives a third address on a free webmail service. An official body wouldn't use free webmail.
- The sending server wasn't authorized for ecb[.]com (SPF softfail) and the domain's rule said to quarantine it (DMARC fail). It was relayed through an unrelated company's server (fvp-it[.]de), probably compromised or badly set up.
- **Too good to be true:** “a pending fund which remains in a dormant state”, plus a shouting subject line.

How the attack works: this is an advance-fee scam. You reply, and they ask for “fees”, “taxes” or your bank details to release money that doesn't exist.

Verdict: Phishing (an advance-fee scam).

One suspicious email and one safe one

S7 · Public sample 7 · 7 Sep 2023

SUSPICIOUS

A real Google notification carrying a stranger's lure

Sent as “Google Notifications” <notify-noreply@google[.]com> · Subject: “<a stranger's odd name> invited you to view a collection…”

SPF pass | DKIM pass | DMARC pass

- **The email itself is genuine.** Every check passes and the links go to Google addresses.
- But I never asked for it: a stranger with a random-looking name shared a “collection” with me, and the title is gibberish (“we hope our chosen opt”).
- The description contains a Google Forms link and the words “Go to form”. Google only delivered the message; the stranger wrote the content.
- I can't see what the form asks without opening it, so I can't prove harm, and I didn't open it.

How the attack works: attackers abuse features of trusted services (sharing, invites, comments) so their message arrives from a real address and passes every check. The danger is the link inside, not the sender.

Verdict: Suspicious. Technically genuine, but unexpected and unverifiable. I would not open it, and I would report it.

S8 · My inbox · 19 Aug 2026

SAFE

LinkedIn legal notice (the safe control)

Sent as “LinkedIn” <messages-noreply@linkedin[.]com> · Subject: “Reminder: Information Technology Rules”

SPF pass | DKIM pass (two signatures) | DMARC pass (policy: reject)

- The sender domain, linkedin[.]com, matches the brand, and the bounce address is a LinkedIn subdomain.
- All three checks pass, and LinkedIn's DMARC policy is the strictest, “reject”, so a forged copy would be thrown away.
- **Calm wording:** it says it is “merely a reminder”, doesn't threaten my account, and never asks for a password, code or payment. No attachments.
- Every link goes to linkedin[.]com. The long tracking parameters are normal for notification emails and are not a red flag on their own.
- The footer explains why I received it and where to get help.

Good habit even here: if I hadn't expected it, I would open LinkedIn myself instead of clicking anything in the email.

Verdict: Safe. It is the mirror image of the phishing emails: matching sender, passing checks, no pressure, no request.

How a phishing attack works

The attacker doesn't need to break into anything. They only need you to do the last step yourself. Almost every email I analyzed followed the same four steps.

1

The bait

A message that looks like it comes from a bank, Microsoft, a courier or an official body.

In my samples: the fake bank notice (S4) and the fake Microsoft alert (S2).

→

2

The pressure

Fear, a deadline or a reward, so you act before you think.

In my samples: “within 24 hours” (S1) and “Final Fund Release Notice!!!” (S6).

→

3

The action

You click a link, open a file, reply, or send a code or money.

In my samples: the Drive link and PDF (S5) and the “Report The User” reply button (S2).

→

4

The payoff

The attacker gets your password or money, or uses your account to attack others.

This is the part I deliberately did not trigger.

FIVE TRICKS I SAW IN MY SAMPLES

1. **Pretend to be someone you trust.** A familiar name, logo or official-sounding title (S2, S3, S4, S6).
2. **Create pressure.** A deadline, a threat or a prize (S1, S4, S5, S6).
3. **Hide the real destination.** Redirect links, links on trusted sites, or buttons that are really email links (S2, S3, S4, S5, S7).
4. **Hide behind a trusted service.** Real Gmail and Google accounts pass the automatic checks (S5, S7).
5. **Make you do the work.** Click, reply, open, type: the victim takes the final step (all of them).

A 30-SECOND HABIT: STOP, LOOK, VERIFY

Stop when an email rushes you. **Look** at the real sender address, where the link really goes, and whether the Reply-To matches. **Verify** through another channel, such as the company's own app or a phone number you already trust.

05 — AWARENESS GUIDE

The ten red flags to check

#	RED FLAG	WHAT TO LOOK FOR	WHERE I SAW IT
1	**Sender doesn't match the brand**	The display name says Microsoft or a bank, but the address ends in some other domain.	S2, S3, S4, S6
2	**Mismatched addresses**	The From, Reply-To and Return-Path point to different places, so replies go to someone else.	S2, S3, S6
3	**Urgency or fear**	“Within 24 hours”, “account locked”, “final notice”, exclamation marks.	S1, S4, S5, S6
4	**Generic greeting**	“Dear User” or “Dear Client” instead of your name.	S1, S4
5	**Links that hide the destination**	Hover before you click. Watch for redirects and links on trusted sites that lead somewhere else.	S4, S5, S7
6	**Unexpected attachments**	A file you didn't ask for, often a PDF or document with a link inside.	S5
7	**Money from nowhere**	Prizes, funds, refunds or “withdrawals” you never asked for.	S5, S6
8	**A request for secrets**	Passwords, codes, bank details, or “reply to confirm”. Real companies don't ask by email.	S1, S2, S3, S4, S6
9	**Messy subject lines**	Emojis, slashes, odd symbols, or tricks like “(MOVE TO INBOX)”.	S4, S5, S7
10	**Failed email checks**	SPF, DKIM or DMARC failing is a strong clue. Passing is not proof of safety.	S2, S3, S4, S6

REMEMBER

One red flag alone may be harmless, and a skilled attacker can avoid most of them. When two or more show up, especially pressure plus a request, treat the email as phishing and report it.

05 — AWARENESS GUIDE

Do's and don'ts for employees

DO

- ✓ Check the **real sender address**, not just the name.
- ✓ Hover over a link and read the address before you click, or type the website yourself.
- ✓ Go to the company's website or app directly if an email says your account has a problem.
- ✓ Confirm unexpected requests through **a second channel**, such as a phone number you already know.
- ✓ Report suspicious emails to IT or security, using the “report phishing” button if you have one.
- ✓ Use a **unique password** for every account and turn on **multi-factor authentication**.
- ✓ Keep your computer, browser and antivirus updated.
- ✓ **Slow down.** Urgency is the attacker's favourite tool.

DON'T

- ✗ Don't click links or open attachments you weren't expecting.
- ✗ Don't type a password on a page you reached from an email link.
- ✗ Don't share **passwords, one-time codes or bank details**. No real company asks for them by email.
- ✗ Don't trust an email because it **looks** official. Logos are easy to copy, and passing checks isn't proof.
- ✗ Don't reply to a suspicious email, even to “unsubscribe” or “report”.
- ✗ Don't forward it to colleagues. Send it to IT instead.
- ✗ Don't pay, buy gift cards or send money because an email told you to.
- ✗ Don't stay quiet if you clicked. Report it straight away.

FOUR QUICK PREVENTION TIPS

- **Bookmark** the sites you use for banking and work, and use the bookmarks instead of email links.
- **Be careful on mobile.** Small screens hide the full sender address, so check it before tapping anything.
- **Treat trusted services with care.** A message from Google, Gmail or a cloud-storage service can still carry a stranger's link.
- **Learn from near-misses.** Share suspicious emails with your team (through IT) so others recognize them.

05 — AWARENESS GUIDE

If you think you clicked, and what businesses can do

IF YOU CLICKED A LINK OR REPLIED

1. **Don't panic and don't hide it.** Quick reporting limits the damage, and attackers rely on embarrassment.
2. **Tell IT or security right away** and give them the email.
3. **If you typed a password,** change it now from a device you trust, and change it anywhere else you reused it.
4. **Turn on multi-factor authentication** for the affected account, and sign out of other sessions.
5. **Watch for follow-ups:** unusual sign-in alerts, unexpected messages sent from your account, or changes to payment details.

WHAT A BUSINESS CAN DO

- **Publish SPF, DKIM and DMARC** for your own domain, and move DMARC to “quarantine” or “reject” so forged copies are stopped. The LinkedIn email (S8) shows the strictest setting working.
- **Turn on email filtering** and link scanning, and check how your mail system treats failed checks.
- **Require multi-factor authentication** so a stolen password alone isn't enough.
- **Train staff regularly,** with short examples like the ones in this report, and run safe phishing simulations.
- **Make reporting easy:** a one-click “report phishing” button and a no-blame culture.
- **Have a simple response plan:** who to tell, how to reset accounts, and how to warn others.

06 — SUPPORTING EVIDENCE

What the headers actually said

These are the authentication lines the receiving mail server recorded in each email (domains and IP addresses defanged for safety). They are the raw facts behind the SPF / DKIM / DMARC columns earlier in this report. The next pages show the same results in the two header-analyzer tools.

S3 · forged microsoft[.]com

PHISHING

```
spf=none (sender IP is 103[.]167[.]154[.]120)
smtp.mailfrom=nisihfjoz[.]co[.]uk;
dkim=fail (no key for signature)
header.d=microsoft[.]com;
dmarc=fail action=oreject header.from=microsoft[.]com;
compauth=fail
```

Forged sender caught: DKIM and DMARC both failed.

S2 · lookalike domain

PHISHING

```
spf=none (sender IP is 89[.]144[.]44[.]2)
smtp.mailfrom=thcultarfdes[.]co[.]uk;
dkim=none (message not signed) header.d=none;
dmarc=permerror action=none header.from=access-
accsecurity[.]com;
```

No signature and no usable domain rule: nothing vouches for this sender.

S4 · fake bank

PHISHING

```
spf=none (sender IP is 143[.]55[.]232[.]5)
smtp.mailfrom=mg[.]tdi[.]tc;
dkim=fail (no key for signature) header.d=mg[.]tdi[.]tc;
dmarc=fail action=none
header.from=digitalmashreq[.]mg[.]tdi[.]tc;
compauth=fail
```

The bank-looking domain failed every check and has nothing to do with the real bank.

S6 · fake ECB

PHISHING

```
spf=softfail (sender IP is 195[.]250[.]48[.]102)
smtp.mailfrom=ecb[.]com;
dkim=none (message not signed) header.d=none;
dmarc=fail action=quarantine header.from=ecb[.]com;
compauth=fail
```

The sending server wasn't authorized for the domain it claimed.

S5 · scam from real Gmail

PHISHING

```
spf=pass (sender IP is 209[.]85[.]167[.]66)
smtp.mailfrom=gmail[.]com;
dkim=pass (signature was verified) header.d=gmail[.]com;
dmarc=pass action=none header.from=gmail[.]com;
compauth=pass reason=100
```

Everything passes, yet it is a scam. The checks prove the origin, not the intent.

S7 · genuine Google email

SUSPICIOUS

```
spf=pass (sender IP is 209[.]85[.]166[.]200)
smtp.mailfrom=chime-
notifications[.]bounces[.]google[.]com;
dkim=pass (signature was verified)
header.d=google[.]com;
dmarc=pass action=none header.from=google[.]com;
compauth=pass reason=100
```

Genuine sender, unexpected content: the risk is the link inside.

S8 · LinkedIn (safe control, my inbox)

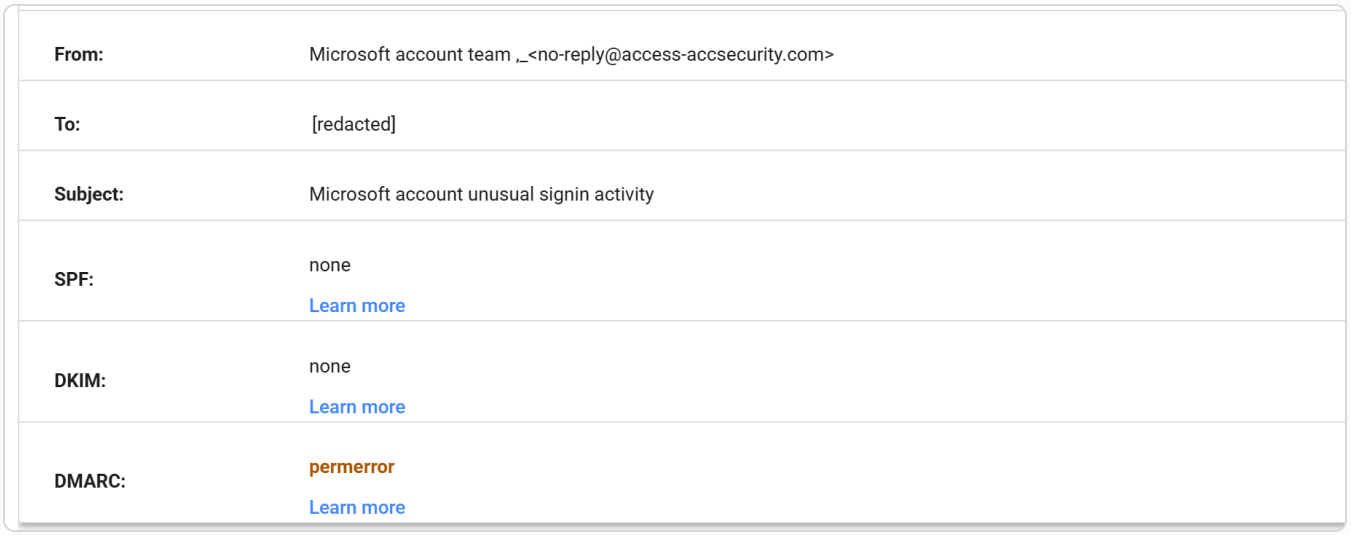
SAFE

```
dkim=pass header.i=@mailf[.]linkedin[.]com header.s=d2048-202308-0f; dkim=pass header.i=@linkedin[.]com header.s=d2048-
202308-00;
spf=pass (google[.]com: domain of [redacted-token]@bounce[.]linkedin[.]com designates 108[.]174[.]3[.]226 as permitted
sender);
dmarc=pass (p=REJECT sp=REJECT dis=NONE) header.from=linkedin[.]com
```

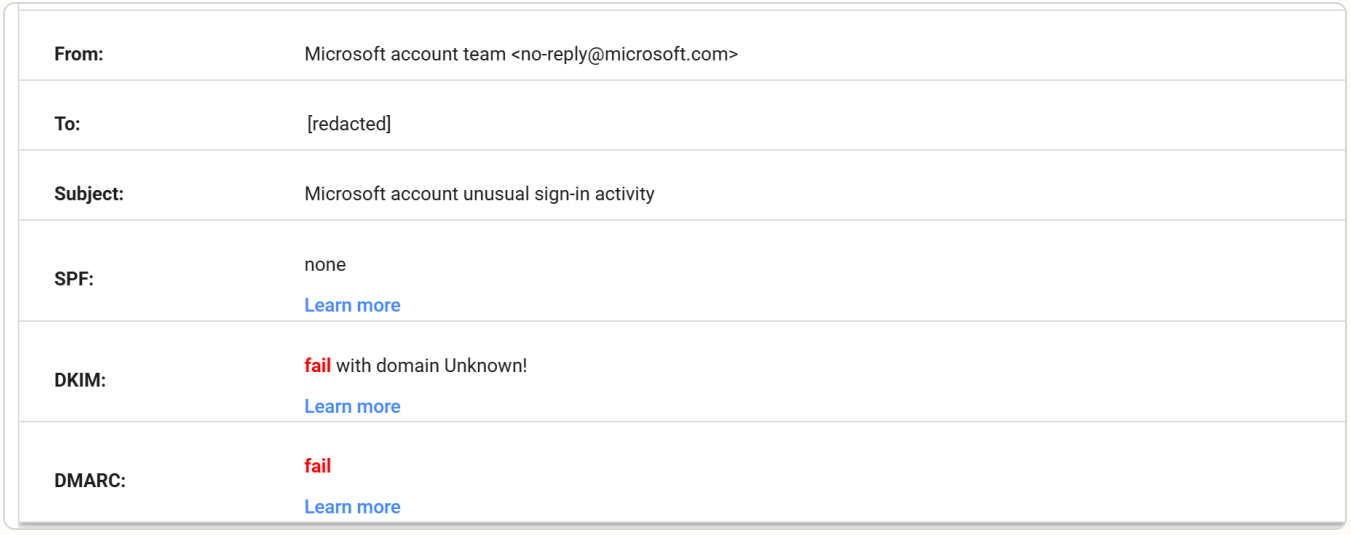
All checks pass and the domain's policy is the strictest, "reject": a forged copy would be thrown away.

Google Admin Toolbox results (1 of 2)

I pasted each sample's saved header into the Google Admin Toolbox Messageheader tool, which reads the SPF, DKIM and DMARC results the receiving mail server recorded. The screenshots are cropped to the result rows; the full images are in the repository's `evidence` folder.



S2, sample 10: fake Microsoft alert from a lookalike domain. The tool shows the sender as access-accsecurity[.]com with SPF **none**, DKIM **none** and DMARC **permerror**, so nothing vouches for this sender. (evidence/Screenshot 2026-10-13 110405.png, cropped)



S3, sample 101: the same alert with the From address forged as microsoft[.]com. SPF is **none**, DKIM **fails** and DMARC **fails**: the forgery is caught. (evidence/Screenshot 2026-10-13 110454.png, cropped)

Google Admin Toolbox results (2 of 2)

From:	Google Notifications <notify-noreply@google.com>
To:	[redacted]
Subject:	dubill hd7t invited you to view a collection: " we hope our chosen opt"
SPF:	**pass** with IP Unknown! Learn more
DKIM:	**pass** with domain Unknown! Learn more
DMARC:	**pass** Learn more

#	Delay	From *		To *	Protocol
0			→	2002:a05:6e02:1c41:b0:348:ba80:5a37	
1			→ [Google]	mail-il1-f200.google.com	SMTP
2		DM6NAM04FT052.eop-NAM04.prod.protection.outlook.com	→	DM6PR02CA0130.outlook.office365.com	
3	1 sec	DS0PR19MB8316.namprd19.prod.outlook.com	→	MN0PR19MB6312.namprd19.prod.outlook.com	

S7, sample 7: the genuine Google notification. SPF, DKIM and DMARC all **pass**, and the relay table shows Google's own mail server (labelled [Google]) handing the message over. The checks pass because Google really sent it; the risk is the stranger's link inside.
(evidence/Screenshot 2026-10-13 110541.png, cropped)

HOW TO READ THESE RESULTS

- The **top table** says who the email claims to be from and shows the three checks. Green **pass** is good, red **fail** is a strong warning, and **none** means no information was available.
- The **relay table** lists every mail server the message passed through, with the delay at each step. The first hops show where the email really started.
- Use the tool together with the wording and the links. A pass is not proof of safety (S5 and S7), and one failure alone doesn't prove bad intent, but several failures plus pressure is a strong sign (S3, S4, S6).

MXToolbox results

The same headers in the MXToolbox Email Header Analyzer, which shows whether DMARC, SPF and DKIM line up and lists every relay hop.



Hop	Delay	From	By	With	Time (UTC)	Blacklist
1	*			HTTP	9/20/2023 10:49:41 AM	
2	1 Second	pc232-5.mailgun.net 143.55.232.5	DB3EUR04FT006.mail.protection.outlook.com 10.152.24.75	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384)	9/20/2023 10:49:42 AM	✗
3	0 seconds	DB3EUR04FT006.eop-eur04.prod.protection.outlook.com 2603:10a6:10:4b3:cafe::30	DUZPR01CA0163.outlook.office365.com 2603:10a6:10:4b3::25	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384)	9/20/2023 10:49:42 AM	✓
4	1 Second	DUZPR01CA0163.eurprd01.prod.exchangelabs.com 2603:10a6:10:4b3::25	PH8PR19MB6952.namprd19.prod.outlook.com 2603:10b6:510:22b::14	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384)	9/20/2023 10:49:43 AM	✓
5	2 seconds	PH8PR19MB6952.namprd19.prod.outlook.com ::1	MN0PR19MB6312.namprd19.prod.outlook.com	HTTPS	9/20/2023 10:49:45 AM	✗

S4, sample 2: fake bank notice. All five checks fail (red crosses). The relay table shows it went out through a Mailgun bulk-mail server, pc232-5[.]mailgun[.]net, which carries a red cross in the Blacklist column. (evidence/Screenshot 2026-10-13 112040.png, relay chart cropped out)



Hop	Delay	From	By	With
1	*	loopback 127.0.0.1	nhf-dc01-brk1.fvp-it.de	ESMTP
2	4 seconds	10.6.8.73	mail01.fvp-it.de	
3	20 minutes	mail01.fvp-it.de 195.250.48.102	VE1EUR01FT010.mail.protection.outlook.com 10.152.2.83	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_SHA384)
4	1 Second	VE1EUR01FT010.eop-EUR01.prod.protection.outlook.com 2603:10a6:910:1c:cafe::49	ZR0P278CA0025.outlook.office365.com 2603:10a6:910:1c::12	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_SHA384)

S6, sample 115: fake European Central Bank email. DMARC compliance, SPF authentication and both DKIM checks fail. The only green tick, SPF alignment, just means the technical sender domain matched the From domain. The relay table shows the message started on an unrelated company's server (fvp-it[.]de) and waited about 20 minutes before reaching Microsoft. (evidence/Screenshot 2026-10-13 112129.png, first hops only)

07 — WRAP-UP

Conclusion, limits and sources

Looking at these eight emails changed how I read my own inbox. The fakes didn't need clever hacking: they borrowed a familiar name, added pressure, and counted on one quick click or reply. What helped most was a short routine that anyone can follow: **check the real sender, check where the link really goes, and check the pressure.** If two of the three feel wrong, stop and verify through another channel.

The most surprising result for me was that a scam email can pass every technical check. Technology catches forgeries like S3, but it can't judge intent, so people remain the last line of defence. That is why the awareness guide matters as much as the analysis.

LIMITS OF THIS ANALYSIS

- It is a small sample: eight emails, most of them from 2022 and 2023.
- I did not click any link or open any attachment, so the “what happens next” parts describe the usual pattern, not something I observed.
- Verdicts are my own judgement based on the headers and content. Check results depend on what each receiving mail server recorded.

SOURCES AND CREDITS

- **Phishing Pot**, a public collection of real phishing emails for researchers (github.com/rf-peixoto/phishing_pot), used under CC BY-NC 4.0 for non-commercial, educational purposes. Excerpts here are modified: redacted and defanged.
- **Google Admin Toolbox Messageheader** and **MXToolbox Email Header Analyzer** for header analysis.
- A small read-only helper script written for this task to list key fields from each email (included in the repository).
- Task brief and example email: Future Interns Cyber Security Task 2.

REPOSITORY

Samples (defanged analysis and redacted headers), tools and evidence: github.com/preetam-pixel/FUTURE_CS_02